

Rapport du SIEM Projet

Client: SEBBAR Anass / UIR

Date: Juin 2025.

Objectives : Ce projet vise à déployer un **SIEM**, simuler deux attaques (DoS, brute force, exploitation de vulnérabilités), analyser les logs générés et proposer des **scénarios d'automatisation** pour améliorer la détection et la réponse aux incidents de sécurité.

Contact Email: mr.lalaoui.rayane@gmail.com

Disclaimer: This report is intended for the client's internal use only. The information contained herein is confidential and should not be disclosed to third parties without prior consent.

Table of Contents

Table of Contents	2
1. Introduction	3
2. Objectifs du Projet.....	3
3. Environnement Technique	3
4. Topologie.....	4
5. Déploiement du SIEM	4
5.1. Installation de Wazuh	5
5.2. Configuration des Agents	6
6. Simulation d'attaques	7
6.1. Scan de Ports avec Nmap	8
6.2. Attaque par Brute Force	8
6.3. Infection par Fichier Malveillant	10
6.4. Attaque sur Active Directory via Responder	12
7. Automatisation et Réponse	16
7.1. Blocage Automatique d'un Scan Nmap	16
7.2. Attaque par Brute Force SSH – Détection et Réponse Automatique	18
7.3. Neutralisation Automatique d'un Compte Utilisateur Malveillant	20
7.4. Attaque sur Active Directory via Responder	23
Conclusion	26
Table de Figure	27

1. Introduction

Ce projet est l'implémentation et la configuration d'un **SIEM** pour regrouper la surveillance des incidents de sécurité. On prévoit de simuler des attaques pour examiner les résultats et suggérer des scénarios d'automatisation dans le but d'améliorer la détection et la réaction aux incidents.

2. Objectifs du Projet

Les objectifs principaux de ce projet sont les suivants :

- Déployer une solution SIEM fonctionnelle dans un environnement sécurisé.
- Simuler des attaques afin d'évaluer la capacité de détection du SIEM.
- Collecter, analyser et corréler les logs pour détecter des comportements anormaux.
- Automatiser les réponses aux incidents.
- Mettre en place des tableaux de bord pour la visualisation des indicateurs de sécurité.
- Intégrer le SIEM à d'autres outils de sécurité comme des IDS/IPS.
- Formuler des recommandations pour améliorer les politiques de sécurité.

3. Environnement Technique

Système SIEM utilisé : Wazuh (open source)

On a Choisi Wazuh car c'est une solution open source de sécurité complète, offrant détection d'intrusions, analyse des logs et gestion des vulnérabilités. Facile à intégrer, compatible avec divers environnements et dotée d'un tableau de bord clair, elle permet une surveillance centralisée et personnalisable, tout en restant gratuite et soutenue par une large communauté.

Système de virtualisation : VMware **Sources de logs dans l'infrastructure :**

1. Machines Linux

- Fournissent des logs système (SSH, sudo, journaux /var/log) pour surveiller les accès, privilèges et actions critiques.

2. Serveur Windows avec Active Directory

- Centralise les logs liés à l'authentification, gestion des comptes et politiques de sécurité dans le domaine.

3. Poste client Windows (géré par l'AD)

- Génère des logs sur l'activité utilisateur, les applications et le système, utiles pour détecter des comportements anormaux.

Outils complémentaires :

On a utilisé une machine d'attaque sous Kali Linux avec les outils Nmap, Metasploit, Hydra, pour simuler des attaques, tester les vulnérabilités et extraire des informations du contrôleur de domaine Active Directory.

4. Topologie

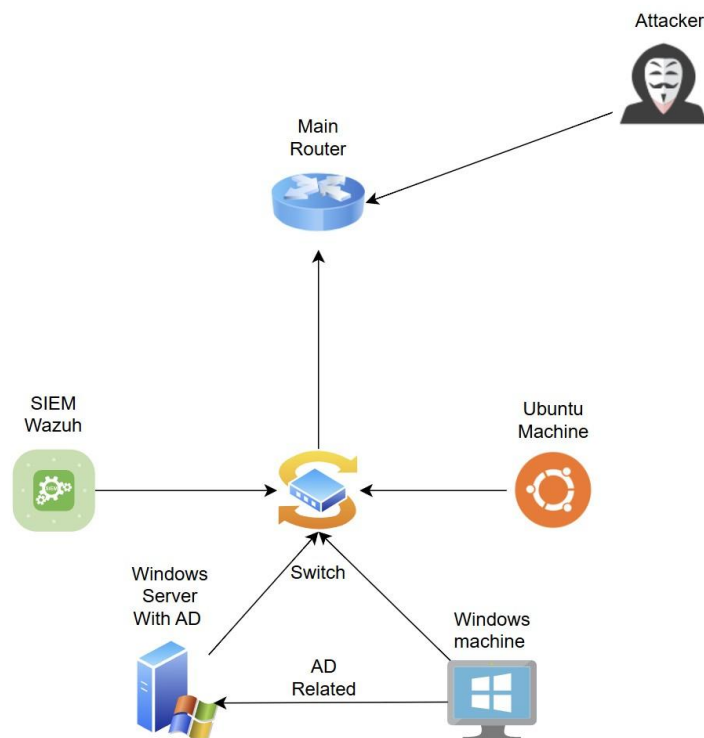


Figure 1: Topologie Du SIEM Utiliser

Cette topologie représente une infrastructure sécurisée utilisée pour un projet SIEM avec Wazuh, intégrant plusieurs machines connectées via un switch central. On y trouve un serveur Windows avec Active Directory qui gère l'authentification et les politiques de sécurité, un poste client Windows rattaché à l'AD, une machine Ubuntu, et un serveur SIEM Wazuh chargé de collecter et analyser les logs des différentes machines. L'ensemble est relié à un routeur principal permettant la communication externe, notamment avec une machine d'attaque (Kali Linux) qui simule des menaces à l'aide d'outils comme Nmap, Metasploit, Hydra ou Wireshark pour tester la robustesse de l'infrastructure et détecter les failles via Wazuh.

5. Déploiement du SIEM

Le déploiement du système SIEM a débuté par l'installation de la solution **Wazuh** en mode **tout-en-un** sur une machine Ubuntu, qui fait office de serveur principal (manager). L'installation s'est déroulée en plusieurs étapes, via des commandes exécutées en ligne de commande.

5.1. Installation de Wazuh

Nous avons utilisé le script officiel fourni par Wazuh pour installer à la fois le manager, l'interface web et l'agent local. Voici les commandes exécutées :

```
cd ~  
curl -sO https://packages.wazuh.com/4.7/wazuh-install.sh chmod +x  
wazuh-install.sh  
sudo ./wazuh-install.sh --all-in-one --verbose
```

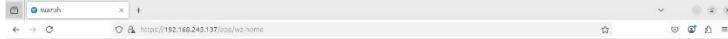


Figure 2: La page de chargement de Wazuh

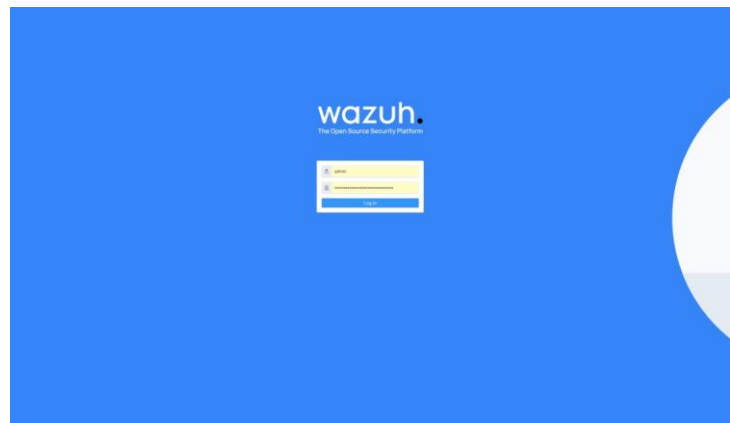


Figure 3: Login Page Wazuh

Une fois l'installation terminée, les identifiants de connexion à l'**interface web de Wazuh** nous ont été fournis automatiquement. L'interface permet de surveiller l'ensemble des agents et des alertes, comme illustré dans la figure ci-dessous.

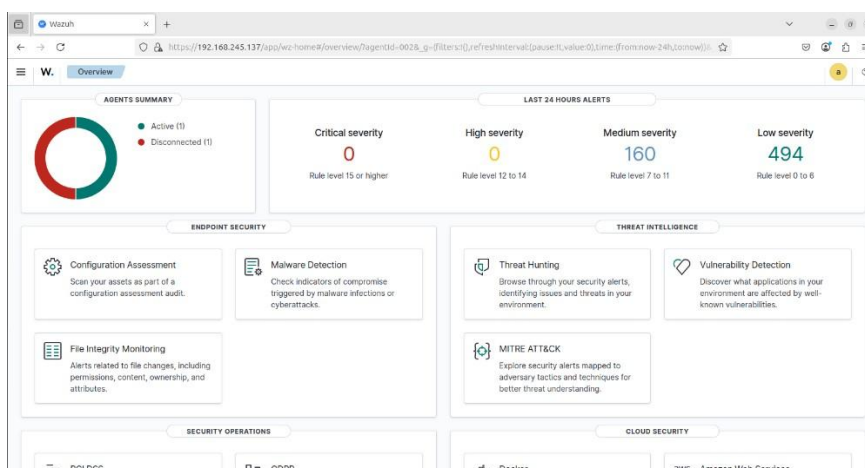


Figure 4: Menu Principale Wazuh

5.2. Configuration des Agents

Après avoir vérifié que l'interface web était opérationnelle, nous avons procédé à la **configuration des agents Wazuh**, qui sont responsables de l'envoi des logs vers le manager. Trois agents ont été configurés :

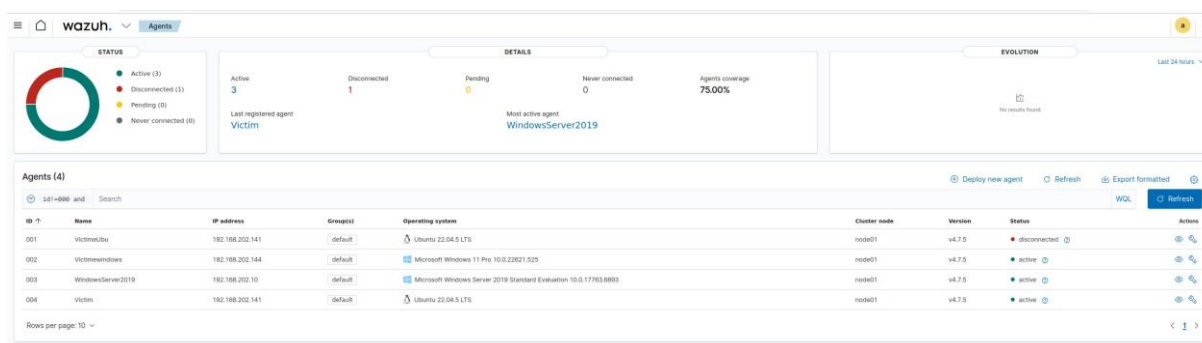


Figure 5: La page Principale des agents

- **Agent 1 : Machine Ubuntu (exploitable)** ○ Utilisée pour générer des logs Linux, comme les connexions SSH, les commandes sudo, et les fichiers /var/log.
 - L'agent Wazuh a été installé en ligne de commande via le dépôt officiel.
- **Agent 2 : Serveur Windows avec Active Directory** ○ Ce serveur joue le rôle de **contrôleur de domaine**. ○ Il centralise les journaux d'événements Windows (logs 4625, 4688, etc.), permettant la surveillance des tentatives d'authentification, des changements de comptes, et des politiques de sécurité.
- **Agent 3 : Poste client Windows (intégré à l'AD)** ○ Représente un utilisateur classique connecté au domaine. ○ Il envoie des logs relatifs à l'activité utilisateur, l'exécution de programmes, et les erreurs système.

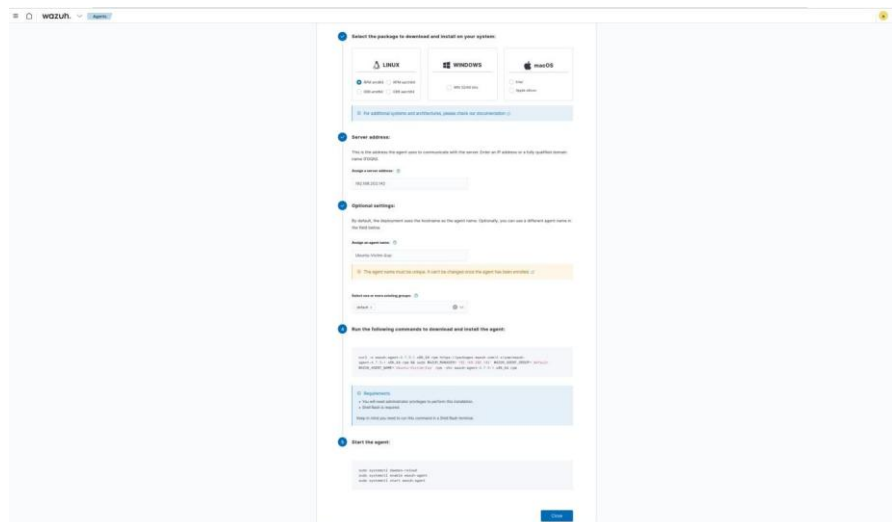


Figure 6: La page d'ajout d'agent

Cette capture d'écran montre l'interface de génération d'un **agent Wazuh** via le tableau de bord du manager. L'utilisateur y sélectionne :

- Le **système d'exploitation** cible (ici Linux en .deb)
- L'**adresse IP du manager** pour permettre la communication entre l'agent et le serveur (192.168.202.141)
- Un **nom d'agent personnalisé** pour l'identifier dans la console (ex. : Ubuntu-Victim)

L'interface génère ensuite un bloc de **commandes d'installation**, à exécuter sur la machine cliente. Ces commandes téléchargent le paquet, le configurent avec l'IP du manager, puis lancent le service wazuh-agent.

Cela permet d'enregistrer facilement un nouvel agent dans l'environnement SIEM.

Après l'ajout de tous les agents, ceux-ci apparaissent dans l'interface du **manager Wazuh** comme illustré dans la figure ci-dessus. On y voit les trois agents correctement enregistrés :

- **Victimewindows** (IP : 192.168.202.144) – Système : *Windows 11 Pro*
- **WindowsServer2019** (IP : 192.168.202.10) – Système : *Windows Server 2019*, avec Active Directory
- **Victim** (IP : 192.168.202.141) – Système : *Ubuntu 22.04.5 LTS*

002	Victimewindows	192.168.202.144	default	Microsoft Windows 11 Pro 10.0.22H2.1525	node01	v4.7.5	active	
003	WindowsServer2019	192.168.202.10	default	Microsoft Windows Server 2019 Standard Evaluation 10.0.17763.6893	node01	v4.7.5	active	
004	Victim	192.168.202.141	default	Ubuntu 22.04.5 LTS	node01	v4.7.5	active	

Figure 7: Les 3 agents Ajouter Dans le SIEM

6. Simulation d'attaques

Dans le cadre de ce projet, plusieurs attaques ont été simulées dans un environnement isolé afin de tester la réactivité du SIEM avant toute personnalisation des règles de détection.

L'objectif était d'évaluer la capacité du système à détecter des comportements malveillants dès l'installation de base.

6.1 Scan de Ports avec Nmap

Un **scan de ports** a été effectué avec **Nmap** pour simuler une phase de reconnaissance. Le scan a permis de lister les ports ouverts et les services actifs sur les machines cibles. Le SIEM a bien détecté cette activité réseau suspecte, l'enregistrant comme un comportement anormal à surveiller.

```

kali@kali:~$ nmap -sS -T4 -A 192.168.245.136
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-03 14:47 EDT
Nmap scan report for 192.168.245.136
Host is up (0.00039s latency).
Not shown: 999 closed tcp ports (reset)
PORT STATE SERVICE
21/tcp open ftp          vsftpd 3.0.5
|_ftp-opts:
|_ssl-cert: Subject: commonName=tsufuso/organizationName=uir/stateOrProvinceName=rabat/countryName=MA
|_Not valid after: 2025-03-08T15:08:58
|_22/tcp open  ssh         OpenSSH 8.7p1 Ubuntu Ubuntu8.12 (Ubuntu Linux; protocol 2.0)
|_ssh-hostkey:
|_ 2048 31:79:67:5d:ca:57:ad:7c:aa:97:73:49:31:3c:96:ca (RSA)
|_ 256  f5:3b:18:02:19:d1:3a:27:82:da:1b:b2:44:3c:fe:f5 (ECDSA)
|_ 256  22:d7:0b:db:60:0a:aa:70:1c:ac:eb:96:92:27:0a:ef (ED25519)
|_23/tcp open  telnet      Linux telnetd
|_25/tcp open  domain     ISC BIND 9.18.18-Ubuntu0.20.04.2 (Ubuntu Linux)
|_dns-nsid:
|_  bind.version: 9.18.18-Ubuntu0.20.04.2-Ubuntu
|_26/tcp open  http        Apache Httpd 2.4.29 ((Ubuntu))
|_http-title: Apache Ubuntu Default Page: It works
|_http-server-header: Apache/2.4.29 (Ubuntu)
MAC Address: 08:0C:29:1F:AC:89 (VMware)
Device type: general purpose
Running: Linux 4.X.X.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.8
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
  hop RTT      ADDRESS
  0  0.39 ms  192.168.245.136

UP and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.52 seconds

```

Figure 8: L'execution de l'attaque NMAP

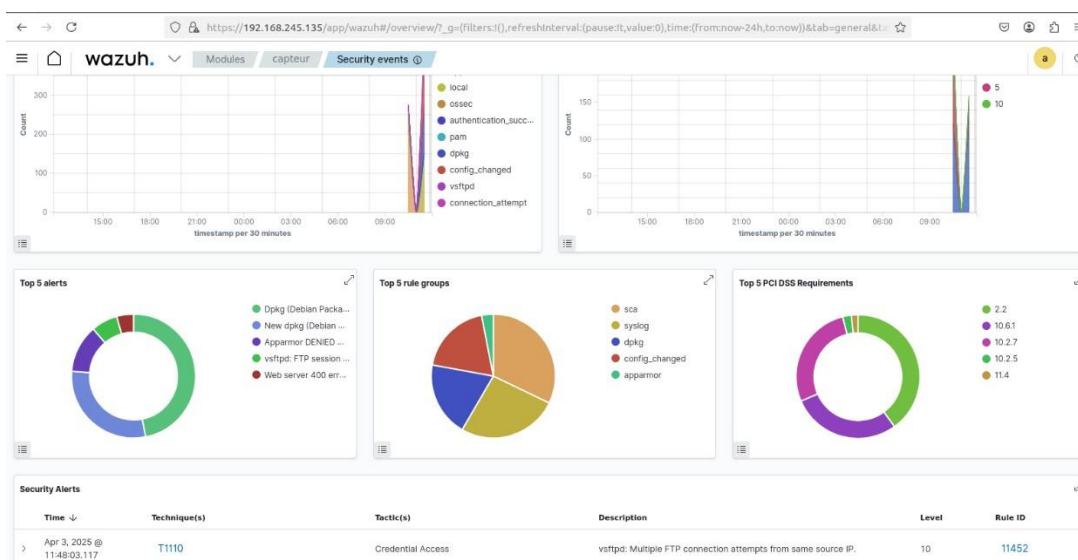


Figure 9: Reaction du SIEM apres L'attaque NMAP

6.2 Attaque par Brute Force

L'attaque initiale a consisté en une tentative de force brute sur les services SSH et RDP à l'aide de l'outil **Metasploit**, exécutée depuis une machine Kali Linux. L'objectif était de deviner les

identifiants valides en lançant une série de tentatives automatisées contre la machine cible Ubuntu.

```
msf6 auxiliary(scanner/ssh/ssh_login) > set USERNAME orme
USERNAME => orme
msf6 auxiliary(scanner/ssh/ssh_login) > set RHOSTS 192.168.202.141
RHOSTS => 192.168.202.141
msf6 auxiliary(scanner/ssh/ssh_login) > run
[*] 192.168.202.141:22 - Starting brute force
[*] 192.168.202.141:22 - Success: 'orme:4852' 'uid=1000(orme) gid=1000(orme) groups=1000(orme),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),122(lpadmin),135(lxd),136(sambashare) Linux orme 6.8.0-52-generic #53-22.04.1-Ubuntu SMP PREEMPT_DYNAMIC Wed Jan 15 19:18:46 UTC 2 x86_64 x86_64 GNU/Linux '
[*] SSH session 1 opened (192.168.202.154:42697 -> 192.168.202.141:22) at 2025-05-18 12:50:07 +0200
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/ssh/ssh_login) >
```

Figure 10: Utilisation de Metasploit avec l'outil ssh_login

Cette capture montre l'outil Metasploit utilisé pour exécuter le module ssh_login, configuré avec l'utilisateur orme et la cible 192.168.202.141. Après plusieurs tentatives, une session SSH a été ouverte avec succès, validant que le mot de passe correct a été trouvé.

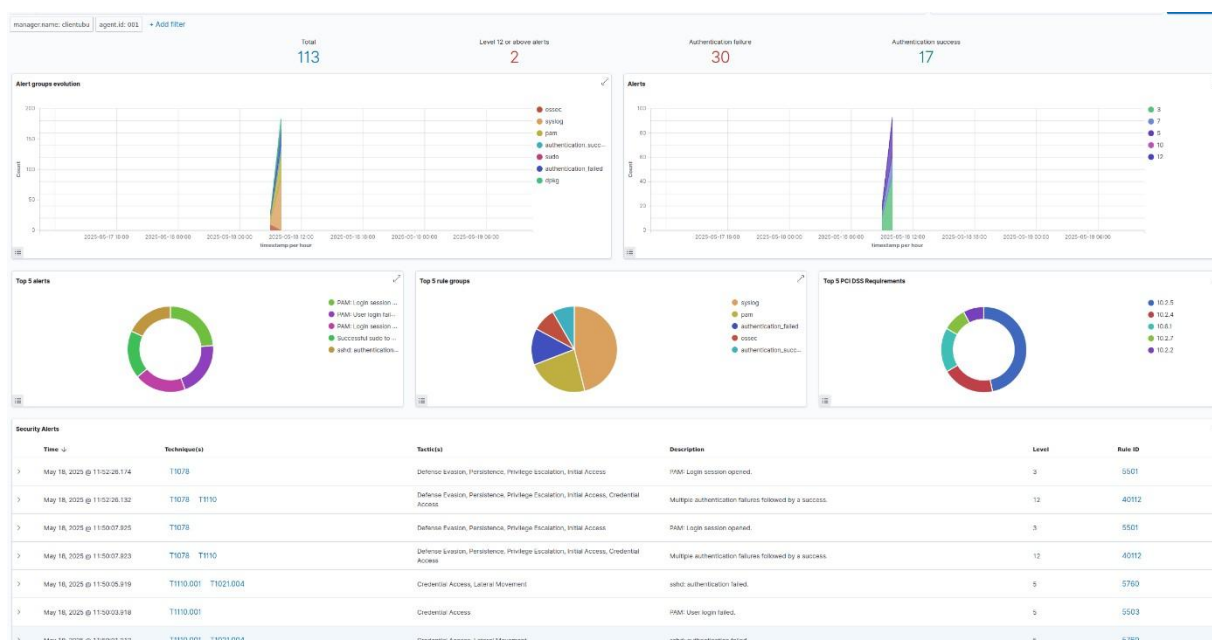


Figure 11: Visualisation des alertes dans le tableau de bord Wazuh

Le tableau de bord de Wazuh montre un pic dans les échecs d'authentification (30), suivi de plusieurs réussites (17), à l'heure correspondant aux attaques. On observe également les règles les plus déclenchées (PAM login failure, SSHD), ce qui confirme le bon fonctionnement du **système de détection et de journalisation** des événements.

Security Alerts					
Time	Technique(s)	Tactic(s)	Description	Level	Rule ID
May 18, 2023 @ 11:50:07.920	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	PMF: Login session opened.	3	5501
May 18, 2023 @ 11:50:07.823	T1078 T1110	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Credential Access	Multiple authentication failures followed by a success.	12	40112

Table	JSON	Rule
@timestamp		2023-05-18T10:50:07.902Z
_id		8_KD40780nD0uJ0uJ8Bq
agent.id		001
agent.ip		192.168.202.141
agent.name		Victim001ba
data.details		none
data.endip		192.168.202.154
data.port		42497
decoder.name		sniff
decoder.parent		sniff
full.log		May 18 11:50:08 orme sshd[37816]: Accepted password for orme from 192.168.202.154 port 42497 ssh2
id		1747965407.447015
input.type		log
location		Awake/juash.log
manager.name		clientsba
productcolor.background		none
productcolor.program.name		sniff
productcolor.timestamp		May 18 11:50:08
rule.description		Multiple authentication failures followed by a success.
rule.firetimes		1
rule.frequency		2
rule.id		6C3672c19C3822
rule.level		12, 3, 7, 8
rule.groups		system, attacks

Figure 12: Le message d'alerte dans le SIEM (Brute force SSH)

Ce screen montre une alerte générée par le SIEM suite à l'ouverture d'une session SSH. Le log révèle que l'utilisateur orme s'est connecté depuis l'adresse IP 192.168.202.154 vers 192.168.202.141, après plusieurs échecs. Cela confirme la détection par Wazuh d'un schéma de brute force réussi, associé aux techniques MITRE **T1078** (Valid Account) et **T1110** (Brute Force).

6.3 Infection par Fichier Malveillant

Une attaque par **ingénierie sociale** a été simulée en envoyant un fichier piégé à une machine victime. Le fichier se présentait comme un document normal, mais en réalité, il contenait un script. Lors de son exécution, ce script créait un **nouvel utilisateur système nommé "pirate"**, indiquant une compromission de la machine. Le SIEM a détecté cette action inhabituelle, **Figure 13: L'attaque avec un fichier Malveillant** signalant la création soudaine d'un compte utilisateur.

```
(kali@kali)-[~/Desktop]
$ echo "rm -rf / --simulate" > fake-malware.sh
chmod +x fake-malware.sh
scp fake-malware.sh ubuntu@192.168.245.136:/tmp/

The authenticity of host '192.168.245.136 (192.168.245.136)' can't be established.
ED25519 key fingerprint is SHA256:7r00Bm8IWvznI42iVU9twFSKf9uuyrggmhOdifLQR5k.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:1: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.245.136' (ED25519) to the list of known hosts.
ubuntu@192.168.245.136's password:
fake-malware.sh

(kali@kali)-[~/Desktop]
```

```

ubuntu@ubuntu:/tmp$ ./fake-malware.sh
[+] Simulation d'activité malveillante pour déclencher Wazuh
Simulation malware
[sudo] password for ubuntu:
Matching Defaults entries for ubuntu on ubuntu:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User ubuntu may run the following commands on ubuntu:

```

Figure 14: l'exécution du code dans la machine victime

Cette simulation d'attaque consistait à exécuter un script malveillant (fake-malware.sh) sur une machine Ubuntu afin de déclencher des alertes dans Wazuh. Le script, lancé avec les droits sudo, a créé un nouvel utilisateur nommé "pirate", simulant ainsi une élévation de privilèges et un mécanisme de persistance. Wazuh a immédiatement détecté plusieurs événements : l'ouverture d'une session root (T1078), la création d'un nouvel utilisateur (T1136) et l'exécution d'une commande sensible (T1548.003). Toutes ces actions ont été enregistrées à la même seconde, démontrant l'efficacité du SIEM à corréler des activités suspectes et à identifier les tactiques comme l'accès initial, l'escalade de privilèges et l'évasion de défense, **comme vous pouvez le voir à travers l'ensemble des captures ci-dessous.**

Time ↓	Technique(s)	Tactic(s)	Description	Level	Rule ID
> Apr 3, 2025 @ 11:59:15.911			PAM: Login session closed.	3	5502
> Apr 3, 2025 @ 11:59:15.908	T1136	Persistence	New user added to the system.	8	5902
> Apr 3, 2025 @ 11:59:15.906			New group added to the system.	8	5901
> Apr 3, 2025 @ 11:59:15.904	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	PAM: Login session opened.	3	5501
> Apr 3, 2025 @ 11:59:15.901	T1548.003	Privilege Escalation, Defense Evasion	Successful sudo to ROOT executed.	3	5402

Figure 15: Détection de l'attaque par le SIEM

Time ↓	Technique(s)	Tactic(s)	Description	Level	Rule ID
> Apr 3, 2025 @ 11:59:15.904	T1078	Defense Evasion, Persistence, Privilege Escalation, Initial Access	PAM: Login session opened.	3	5501

Table	JSON	Rule
@timestamp:	2025-04-03T18:59:15.904Z	
_id:	y6MF_ZuB1yhe090umcJL	
agent.id:	001	
agent.ip:	192.168.245.136	
agent.name:	captur	
data.distributor:	root	
data.uid:	0	
decoder.name:	pam	
decoder.parent:	pam	
full_log:	Apr 3 11:59:15 ubuntu sudo: pam_unix(sudo_session): session opened for user root by (uid=0)	
id:	1743706755.1731691	
input.type:	log	
location:	/var/log/auth.log	
manager.name:	ubuntu	
predecoder.hostname:	ubuntu	

Figure 16: Détection de l'ouverture d'une session root via sudo (T1078 - Initial Access)

Apr 3, 2025 @ 11:58:15.901	T1548.003	Privilege Escalation, Defense Evasion	Successful sudo to ROOT executed.	3	5402
Table	JSON	Rule			
@timestamp	2025-04-03T18:58:15.901Z				
_id	ysMF_ZuB1yNwOB0emcJL				
agent.id	001				
agent.ip	192.168.245.136				
agent.name	capteur				
data.command	/usr/sbin/useradd -m pirate				
data.dstuser	root				
data.pwd	/tmp				
data.srcuser	ubuntu				
data.tty	pts/0				
decoder.description	First time user executed the sudo command				
decoder.name	sudo				
decoder.parent	sudo				
full_log	Apr 3 11:58:15 ubuntu sudo: ubuntu : TTY=pts/0 ; PWD=/tmp ; USER=root ; COMMAND=/usr/sbin/useradd -m pirate				

Figure 17: Création d'un utilisateur pirate via une commande root (T1548.003 - Privilege Escalation)

location	/var/log/auth.log
manager.name	ubuntu
predecoder.hostname	ubuntu
predecoder.program.name	useradd
predecoder.timestamp	Apr 3 11:58:15
rule.description	New user added to the system.
rule.firetimes	1
rule.gdpr	N,35,7,d,N,32,2
rule.gpg13	4,13
rule.groups	syslog,adduser
rule.hipaa	164.312.6, 164.312.a.2.i, 164.312.a.2.ii
rule.id	5902
rule.level	8
rule.mal	false
rule.mitre.id	T1136
rule.mitre.tactic	Persistence
rule.mitre.technique	Create Account
rule.nist_800_53	Au.14, AC.7, AC.2, IA.4
rule.pci.dss	10.2.7, 10.2.8, 6.1.2
rule.tsc	CC6.8, CC7.2, CC7.3
timestamp	2025-04-03T11:58:15.908Z

Figure 18: Détection de la création d'un nouvel utilisateur pirate (T1136 – Persistence)

✓

Apr 3, 2025 @ 11:58 15.908

T1136

Persistence

New user added to the system.

8

5902

Table

JSON

Rule

@timestamp

2025-04-03T18:58:15.908Z

_id

zckMF_ZuB1yNe08OmncJL

agent.id

001

agent.ip

192.168.245.136

agent.name

capteur

data.dstuser

pirate

data.gid

1011

data.home

/home/pirate

data.shell

/bin/sh

data.uid

1007

decoder.name

useradd

decoder.parent

useradd

full_log

Apr 3 11:58:15 ubuntu useradd[24305]: new user: name=pirate, UID=1007, GID=1011, home=/home/pirate, shell=/bin/sh, from=/dev/pts/0

id

1743706755.1732575

input.type

log

location

/var/log/auth.log

Figure 19: Journal détaillé de la création de L'utilisateur "pirate" détectée par Wazuh (T1136 – Persistence)

6.4 Attaque sur Active Directory via Responder

Une attaque a été réalisée contre l'**Active Directory** à l'aide de l'outil **Responder**. L'objectif était d'intercepter les requêtes de type réseau (LLMNR/NBT-NS) pour récupérer les **hashs NTLMv2** de l'utilisateur administrateur. L'attaquant, en utilisant un **sniffer réseau sur Kali Linux**, a capturé ces hashes puis les a soumis à **Hashcat** avec un dictionnaire (rockyou.txt) pour

retrouver le **mot de passe en clair**. Grâce à ces identifiants, il a ensuite pu accéder aux ressources du domaine.

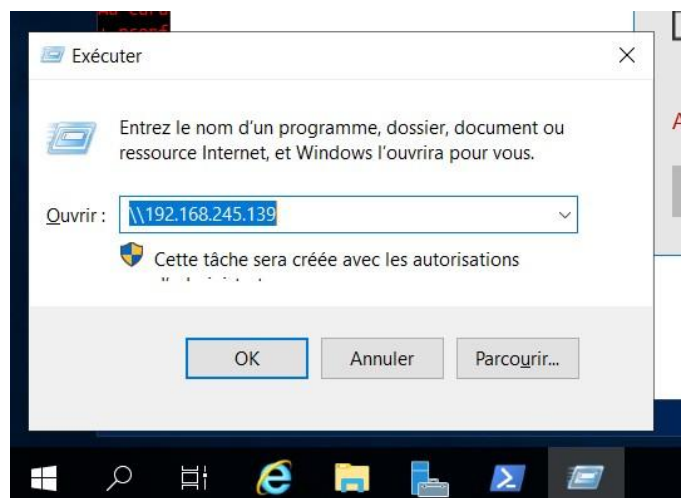


Figure 20: Accès depuis Windows Server

Cette capture d'écran illustre un utilisateur exécutant une connexion via le protocole **NTLM** à l'adresse IP \\192.168.245.139, en supposant qu'il accède normalement à un partage réseau. Dans notre scénario, cette action a été exploitée pour simuler une attaque de type **man-in-the-middle** à l'aide de l'outil **Responder**, qui intercepte les requêtes SMB. En capturant les paquets échangés, notamment les **hashs NTLM**, l'attaquant peut ensuite lancer une **attaque par dictionnaire** pour récupérer les identifiants d'un administrateur. Cette étape marque le début de la compromission, comme vous pouvez le constater dans les captures suivantes.

Ce screen montre l'exécution de la commande `responder -l eth0 -dwv`, activant les modules LLMNR, NBT-NS, MDNS, DNS, DHCP, ainsi que plusieurs serveurs comme SMB, HTTP et HTTPS. Cela permet à l'attaquant d'intercepter les requêtes de découverte réseau envoyées par les machines du domaine.



Figure 21: Lancement de l'outil Responder

[illegible]

Figure 22: Interception des hashes NTLMv2

Ici, Responder a intercepté plusieurs **hashs NTLMv2** provenant de la machine victime (192.168.245.144) avec l'utilisateur LOCALAD\Administrateur. Ces informations sont essentielles pour lancer une attaque de type cracking hors-ligne.

```
(kali@kali:~)$ hashcat -m 5600 ntlmv2.txt /usr/share/wordlists/rockyou.txt --force --potfile-disable
```

```
hashcat (v6.2.6) starting
```

```
You have enabled --force to bypass dangerous warnings and errors!
This can hide serious problems and should only be done when debugging.
Do not report hashcat issues encountered when using --force.
```

```
OpenCL API [OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, LLVM 17.0.6, SLEEF, DISTRO, POCL_DEBUG] - Platform #1 [The pocl project]
```

```
* Device #1: cpu-sandybridge-11th Gen Intel(R) Core(TM) i7-11800H @ 2.30GHz, 1435/2935 MB (512 MB allocatable), 6MCU
```

```
Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256
```

```
Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1
```

```
Optimizers applied:
* Zero-Byte
* Not-Iterated
* Single-Hash
* Single-Salt
```

```
ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.
```

```
Watchdog: Temperature abort trigger set to 90c
```

```
Host memory required for this attack: 0 MB
```

```
Dictionary cache hit:
```

```
* Filename .. /usr/share/wordlists/rockyou.txt
* Passwords.: 14344387
* Bytes.....: 139921528
* Keyspace...: 14344387
```

```
ADMINISTRATOR::LOCALAD:3490da6b423fb619:c9bd0aa9fd3105ace479e1bfdf907a4:01010000000000000000c95c08bcdcb0146633da17967c8d00000000000000520b36002400340001001e00570049004e002d00030003000580035003400800380038005800560004003400570049004e002d00057003000300058003500340080038003800580056002e005203600420034002e004c004f004300410094c00300140052003600420034002e004c004f00430041004c00
```

Figure 23: Utilisation de Hashcat pour casser le hash

Dans cette étape, l'attaquant utilise Hashcat avec le mode -m 5600 (NTLMv2) et le dictionnaire rockyou.txt pour tenter de retrouver le mot de passe en clair à partir du hash capturé. Le hash est stocké dans un fichier ntlmv2.txt.

[illegible]

Figure 24: Hash cracké avec succès

Le hash a été **craqué avec succès**. Le mot de passe de l'administrateur récupéré est admin@2025. Cette étape valide l'efficacité de l'attaque et donne à l'attaquant les moyens d'entrer dans le réseau cible avec des privilèges élevés.

```
(kali㉿kali)-[~]
$ smbclient //192.168.245.144/C$ -U 'LOCALAD\\Administrateur'
Password for [Administrateur]:
Try "help" to get a list of possible commands.
smb: \> ls
$Recycle.Bin                DHS                0   Sat Sep 15 03:19:00 2018
Documents and Settings      DHSrn          0   Wed Feb 19 08:53:34 2025
inetpub                     D              0   Wed Feb 26 11:23:07 2025
pagefile.sys                AHS 1476395008  Sat May 3 07:34:04 2025
PerfLogs                    D              0   Sat Nov 5 15:14:30 2022
Program Files                DR             0   Wed Mar 26 10:08:25 2025
Program Files (x86)         D              0   Fri May 2 09:04:01 2025
ProgramData                 DHn            0   Fri May 2 10:15:11 2025
Recovery                    DHSn           0   Wed Feb 19 08:53:41 2025
System Volume Information   DHS           0   Wed Mar 12 09:15:52 2025
Users                       DR             0   Fri May 2 10:00:50 2025
Windows                     D              0   Fri May 2 10:07:37 2025

15570943 blocks of size 4096. 12037336 blocks available
smb: \>
```

Figure 25: Accès réussi au partage Windows via SMB

Grâce aux identifiants LOCALAD\Administrateur et au mot de passe craqué, l'attaquant a pu se connecter avec succès au **partage SMB distant** et lister les répertoires du système. Cela confirme que le compte compromis permet un **accès total** à la machine.

7. Automatisation et Réponse

7.1. Blocage Automatique d'un Scan Nmap

Dans cette phase, nous avons mis en place une règle personnalisée dans Wazuh permettant de détecter une activité de **scan réseau via Nmap** et d'y répondre automatiquement. Une fois cette configuration terminée, nous avons lancé un **scan SYN avancé (Nmap -sS -A)** depuis une machine Kali Linux sur une machine Ubuntu.

Le premier scan a permis de détecter les ports ouverts et les services actifs. Immédiatement après, Wazuh a analysé les logs, identifié l'activité comme un **scanning anormal** et déclenché une **réponse active** en bloquant l'adresse IP source de l'attaquant à l'aide d'un script firewall-drop. Ensuite, une **nouvelle tentative de scan Nmap a échoué**, prouvant que le blocage a été correctement appliqué.

data.parameters.alert.data.protocol	PROPFIND
data.parameters.alert.data.srcip	192.168.245.139
data.parameters.alert.data.url	/
data.parameters.alert.decoder.name	web-accesslog
data.parameters.alert.decoder.parent	web-accesslog
data.parameters.alert.full_log	www.sec522.com:80 192.168.245.139 - - [01/Jun/2025:10:58:55 -0400] "PROPFIND / HTTP/1.1" 405 525 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)"
data.parameters.alert.id	1748789936.1780707
data.parameters.alert.location	/var/log/apache2/access.log
data.parameters.alert.manager.name	ubuntu-VMware-Virtual-Platform
data.parameters.alert.previous_output	>  www.sec522.com:443 192.168.245.139 - - [01/Jun/2025:10:58:55 -0400] "GET /HNAP1 HTTP/1.1" 404 5904 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)" www.sec522.com:80 192.168.245.139 - - [01/Jun/2025:10:58:55 -0400] "POST /sdk HTTP/1.1" 404 457 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)" www.sec522.com:80 192.168.245.139 - - [01/Jun/2025:10:58:55 -0400] "GET /evox/about HTTP/1.1" 404 457 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)" www.sec522.com:443 192.168.245.139 - - [01/Jun/2025:10:58:55 -0400] "GET /evox/about HTTP/1.1" 404 5904
data.parameters.alert.rule.description	Multiple web server 400 error codes from same source ip.
data.parameters.alert.rule.firedtimes	1
data.parameters.alert.rule.frequency	14
data.parameters.alert.rule.gdpr	IV_35.7.d

Figure 26: Détection du scan dans les logs

Le fichier /var/log/apache2/access.log contient des requêtes typiques du moteur de script Nmap (Mozilla/5.0 (Nmap Scripting Engine)) avec des erreurs 404/405. Ces logs sont automatiquement analysés par Wazuh, déclenchant une alerte.

data.parameters.alert.rule.firedtimes	1
data.parameters.alert.rule.frequency	14
data.parameters.alert.rule.gdpr	IV_35.7.d
data.parameters.alert.rule.groups	web, accesslog, web_scan, recon
data.parameters.alert.rule.id	31151
data.parameters.alert.rule.level	10
data.parameters.alert.rule.mail	false
data.parameters.alert.rule.mitre.id	T1595.002
data.parameters.alert.rule.mitre.tactic	Reconnaissance
data.parameters.alert.rule.mitre.technique	Vulnerability Scanning
data.parameters.alert.rule.nist_800_53	SA.11, SI.4
data.parameters.alert.rule.pci_dss	6.5, 11.4
data.parameters.alert.rule.tsc	CC6.6, CC7.1, CC8.1, CC6.1, CC6.8, CC7.2, CC7.3
data.parameters.alert.timestamp	2025-06-01T15:58:56.029+0100
data.parameters.extra_args	
data.parameters.program	active-response/bin/firewall-drop
data.version	1

Figure 27: Alerte générée par Wazuh

Wazuh identifie l'activité comme un **scan de vulnérabilités** selon la tactique MITRE Reconnaissance. La règle 31151 avec un **niveau de sévérité 10** s'active lorsqu'un grand nombre d'erreurs 400 est détecté depuis une seule IP.

decoder.name	ar_log_json
decoder.parent	ar_log_json
full_log	>
id	1748789937.1788114
input.type	log
location	/var/ossec/logs/active-responses.log
manager.name	ubuntu-VMware-Virtual-Platform
rule.description	Host Blocked by firewall-drop Active Response
rule.firedtimes	1
rule.gdpr	IV_35.7.d
rule.gpg13	4.13
rule.groups	ossec, active_response
rule.id	651
rule.level	3

Figure 28: Réponse active exécutée automatiquement (firewall-drop)

Dès la détection du scan, Wazuh a exécuté le script firewall-drop pour bloquer l'attaquant. Cela est confirmé dans le fichier /var/ossec/logs/active-responses.log avec le message **"Host Blocked by firewall-drop Active Response"**.

```

</rule>
<rule id="110100" level="12">
  <field name="alert.signature">ET SCAN Nmap Scripting Engine
  </field>
  <description>Nmap Scan détecté</description>
  <group>nmap,network,scan,active_response</group>
</rule>
290 </active-response>
291 <active-response>
292 <command>firewall-drop</command>
293 <location>local</location>
294 <rules_id>110100</rules_id>
295 <timeout>180</timeout> <!-- 0 = permanent -->
296 <level>12</level>
297 </active-response>

```

Figure 29: Configuration de la règle de réponse dans le fichier XML

Cette règle personnalisée (id=110100) est définie pour réagir aux scans Nmap détectés par signature. Elle déclenche le blocage de l'IP en local via le script firewall-drop pendant un délai de 180 secondes

```

(kali@kali)-[~]
$ nmap -sS -A 192.168.245.129
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-06-01 11:07 EDT
Nmap scan report for 192.168.245.129
Host is up (0.00034s latency).
All 1000 scanned ports on 192.168.245.129 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 00:0C:29:56:C8:77 (VMware)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

TRACEROUTE
HOP RTT ADDRESS
1 0.34 ms 192.168.245.129

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 29.30 seconds

(kali@kali)-[~]
$

```

Figure 30: Nouvelle tentative de scan échouée (preuve de blocage)

Après la réponse active, un second scan Nmap a été exécuté depuis Kali. Cette fois, **aucun port n'a pu être scanné** : tous les paquets sont filtrés, indiquant que la connexion est bloquée par le pare-feu, preuve que la réponse automatique a bien fonctionné.

7.2. Attaque par Brute Force SSH – Détection et Réponse Automatique

Dans cette simulation, nous avons exécuté une attaque par **brute force SSH** sur une machine Linux (192.168.245.129) dans le but de tester la capacité du SIEM à détecter ce comportement et y répondre automatiquement.

L'attaque consistait à envoyer plusieurs tentatives de connexion SSH avec des mots de passe incorrects en peu de temps.

Wazuh a identifié cette activité comme une tentative de **Credential Access (MITRE T1110)** et a déclenché une **réponse active** en bloquant l'adresse IP de l'attaquant grâce à un script firewall-drop.

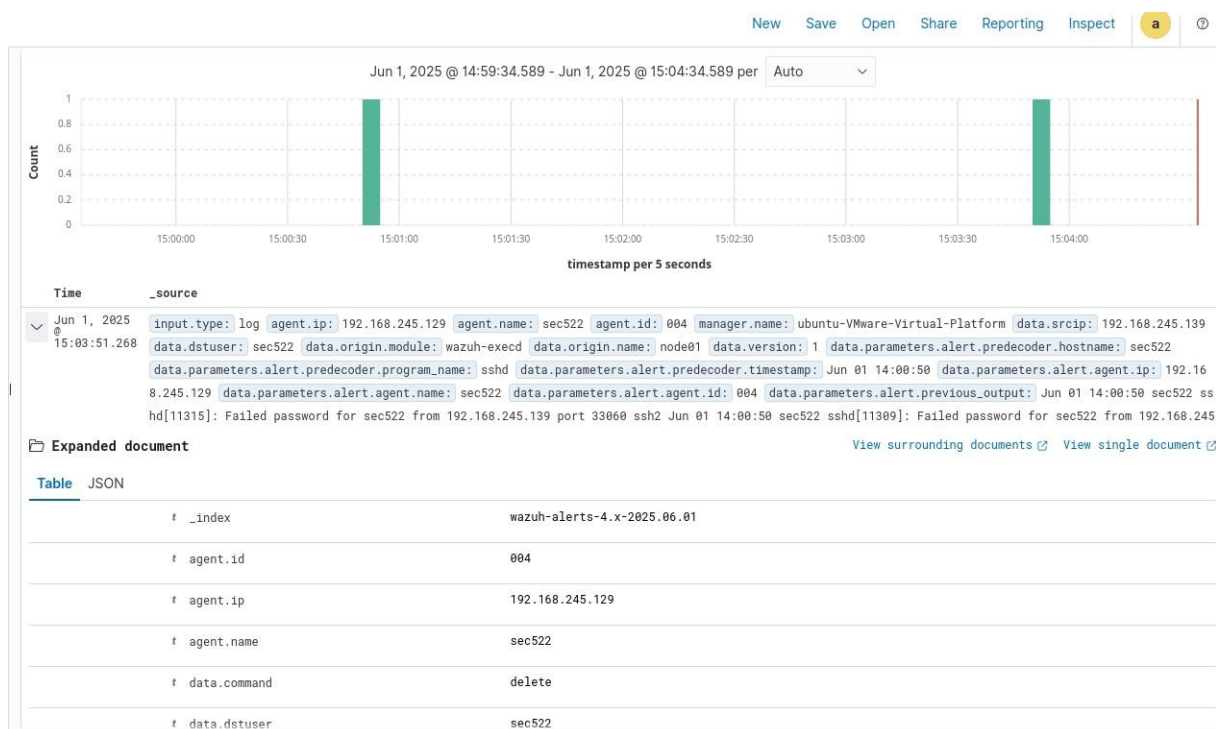


Figure 31: Échec répété de connexions SSH dans les logs

Le journal montre plusieurs tentatives échouées de connexion SSH provenant de l'IP 192.168.245.139 vers l'utilisateur sec522 sur différents ports. Ce comportement est typique d'une attaque brute force.

data.parameters.alert.previous_output	Jun 01 14:00:50 sec522 sshd[11315]: Failed password for sec522 from 192.168.245.139 port 33060 ssh2 Jun 01 14:00:50 sec522 sshd[11309]: Failed password for sec522 from 192.168.245.139 port 33008 ssh2 Jun 01 14:00:50 sec522 sshd[11326]: Failed password for sec522 from 192.168.245.139 port 33130 ssh2 Jun 01 14:00:49 sec522 sshd[11321]: Failed password for sec522 from 192.168.245.139 port 33124 ssh2 Jun 01 14:00:49 sec522 sshd[11313]: Failed password for sec522 from 192.168.245.139 port 33058 ssh2 Jun 01 14:00:49 sec522 sshd[11310]: Failed password for sec522 from 192.168.245.139 port 33000 ssh2 Jun 01 14:00:40 sec522 sshd[11308]: Failed password for sec522 from 192.168.245.139 port 33006 ssh2
data.parameters.alert.rule.description	sshd: brute force trying to get access to the system. Authentication failed.
data.parameters.alert.rule.firedtimes	1
data.parameters.alert.rule.frequency	8
data.parameters.alert.rule.gdpr	IV_35.7.d, IV_32.2
data.parameters.alert.rule.groups	syslog, sshd, authentication_failures
data.parameters.alert.rule.hipaa	164.312.b
data.parameters.alert.rule.id	5763
data.parameters.alert.rule.level	10
data.parameters.alert.rule.mail	false
data.parameters.alert.rule.mitre.id	T1110
data.parameters.alert.rule.mitre.tactic	Credential Access
data.parameters.alert.rule.mitre.technique	Brute Force

Figure 32: Alerte Wazuh déclenchée par fréquence de tentatives

Wazuh déclenche une alerte avec la **règle 5763**, identifiée comme Brute Force. Elle appartient à la tactique MITRE Credential Access avec un **niveau de gravité 10**. La fréquence élevée d'échecs de mot de passe déclenche cette alerte critique.

data.parameters.alert.rule.pci_dss	11.4, 10.2.4, 10.2.5
data.parameters.alert.rule.tsc	CC6.1, CC6.8, CC7.2, CC7.3
data.parameters.alert.timestamp	2025-06-01T15:00:50.992+0100
data.parameters.extra_args	
data.parameters.program	active-response/bin/firewall-drop
data.srcip	192.168.245.139
data.version	1
decoder.name	ar_log_json
decoder.parent	ar_log_json
full_log	> 2025/06/01 10:03:51 active-response/bin/firewall-drop: {"version":1,"origin":{"name":"node01","module":"wazuh-execd"},"command":"delete","parameters":{"extra_args":[],"alert":{"timestamp":"2025-06-01T15:00:50.992+0100"},"rule":{"level":10,"description":"sshd: brute force trying to get access to the system. Authentication failed.","id":"5763","mitre":{"id":["T1110"],"tactic":["Credential Access"],"technique":["Brute Force"]},"frequency":8,"firedtimes":1,"mail":false,"groups":["syslog","sshd"],"authentication_failures"},"gdpr":{"IV_35.7.d","IV_32.2"},"hipaa":["164.312.b"],"nist_800_53":["SI.4","AU.14","AC.7.1","PCI_dss":["11.4","10.2.4","10.2.5"],"tsc":["CC6.1","CC6.8","CC7.2","CC7.3"],"enact":["11.4"]}}
id	1748786631.1719405
input.type	log
location	/var/ossec/logs/active-responses.log
manager.name	ubuntu-VMware-Virtual-Platform

Figure 33: Réponse Active : Blocage automatique via firewall-drop

Après détection, Wazuh a exécuté automatiquement le script firewall-drop, ce qui a bloqué l'IP source de l'attaque (192.168.245.139). Ce blocage est enregistré dans /var/ossec/logs/active-responses.log.

```
<active-response>
  <command>netsh</command>
  <location>local</location>
  <rules_id>110005</rules_id>
  <timeout>600</timeout>
  <level>12</level>
</active-response>

<active-response>
  <disabled>no</disabled>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>5763</rules_id>
  <timeout>180</timeout>
</active-response>
```

Figure 34: Configuration de la réponse active dans le fichier XML

Cette configuration XML montre que la règle 5763 est liée à une réponse active firewallldrop, avec un blocage temporaire de 180 secondes (Pour les Tests). Le niveau requis (level=<12) assure que seules les attaques graves déclenchent cette réponse.

7.3. Neutralisation Automatique d'un Compte Utilisateur Malveillant

Lors de notre simulation, un script malveillant a été exécuté sur une machine Linux cible, entraînant la **création non autorisée d'un compte nommé pirate**. Grâce aux règles

définies dans Wazuh, cette activité a été détectée comme une tentative de persistance via la création d'un compte (technique MITRE T1136 : *Create Account*).

Wazuh a réagi automatiquement en exécutant le script disable-account pour désactiver immédiatement ce compte malveillant.

Jun 1, 2025 18:13:34.777

```
input.type: log agent.ip: 192.168.245.129 agent.name: sec522 agent.id: 004 manager.name: ubuntu-VMware-Virtual-Platform data.dstuser: pirate
data.origin.module: wazuh-execd data.origin.name: node01 data.version: 1 data.parameters.alert.predecoder.hostname: sec522
data.parameters.alert.predecoder.program_name: useradd data.parameters.alert.predecoder.timestamp: Jun 01 17:13:31 data.parameters.alert.agent.ip: 19
2.168.245.129 data.parameters.alert.agent.name: sec522 data.parameters.alert.agent.id: 004 data.parameters.alert.manager.name: ubuntu-VMware-Virtual-P1
atform data.parameters.alert.data.uid: 1003 data.parameters.alert.data.gid: 1004 data.parameters.alert.data.shell: /bin/sh
```

Expanded document

View surrounding documents View single document

Table	JSON
# _index	wazuh-alerts-4.x-2025.06.01
# agent.id	004
# agent.ip	192.168.245.129
# agent.name	sec522
# data.command	add
# data.dstuser	pirate
# data.origin.module	wazuh-execd
data.origin.name	node01
data.parameters.alert.agent.id	004
data.parameters.alert.agent.ip	192.168.245.129
data.parameters.alert.agent.name	sec522

Figure 35: Journal détectant l'ajout du compte pirate

Le journal montre qu'un nouvel utilisateur nommé pirate a été ajouté via la commande useradd. Les informations associées (UID, GID, shell, home) sont affichées. Cet événement a déclenché une alerte de sécurité dans Wazuh.

data.parameters.alert.agent.id	004
data.parameters.alert.agent.ip	192.168.245.129
data.parameters.alert.agent.name	sec522
data.parameters.alert.data.dstuser	pirate
data.parameters.alert.data.gid	1004
data.parameters.alert.data.home	/home/pirate
data.parameters.alert.data.shell	/bin/sh
data.parameters.alert.data.uid	1003
data.parameters.alert.decoder.name	useradd
data.parameters.alert.decoder.parent	useradd
data.parameters.alert.full_log	Jun 01 17:13:31 sec522 useradd[25191]: new user: name=pirate, UID=1003, GID=1004, home=/home/pirate, shell=/bin/sh
data.parameters.alert.id	1748798012.2081455
data.parameters.alert.location	journalid
data.parameters.alert.manager.name	ubuntu-VMware-Virtual-Platform
data.parameters.alert.predecoder.hostname	sec522
data.parameters.alert.predecoder.program_name	useradd

Figure 36: Alerte générée par Wazuh (Create Account - MITRE T1136)

Wazuh a interprété cette activité comme une tentative de persistance. La règle 5902, avec un niveau de gravité 10, a été déclenchée. L'événement est identifié comme une tentative suspecte d'ajout de compte utilisateur.

data.parameters.alert.rule.mitre.technique	Create Account
data.parameters.alert.rule.nist_800_53	AU.14, AC.7, AC.2, IA.4
data.parameters.alert.rule.pci_dss	10.2.7, 10.2.5, 8.1.2
data.parameters.alert.rule.tsc	CC6.8, CC7.2, CC7.3
data.parameters.alert.timestamp	2025-06-01T18:13:32.825+0100
data.parameters.extra_args	
data.parameters.program	active-response/bin/disable-account
data.version	1
decoder.name	ar_log_json
decoder.parent	ar_log_json
full_log	>
id	1748798014.2082882
input.type	log
location	/var/ossec/logs/active-responses.log

Figure 37: Réaction automatique : désactivation du compte pirate

Suite à cette détection, la réponse active disable-account a été exécutée automatiquement par Wazuh. Cela a entraîné la désactivation immédiate du compte créé sans autorisation.

```
<rule id="5902" level="10">
  <decoded_as>syslog</decoded_as>
  <field name="program_name">useradd</field>
  <match>pirate</match>
  <description>New user added to the system.</description>
  <group>syslog,adduser</group>
</rule>

<active-response>
  <disabled>no</disabled>
  <command>disable-account</command>
  <location>local</location>
  <rules_id>5902</rules_id>
  <timeout>0</timeout>
</active-response>

<command>
  <name>disable-account</name>
  <executable>disable-account</executable>
  <timeout_allowed>yes</timeout_allowed>
</command>
```

Figure 38: Configuration XML des règles de désactivation

Les fichiers de configuration XML montrent que la **règle 5902** est associée à la détection d'un ajout de compte contenant le nom pirate, avec un **niveau de gravité élevé (niveau 10)**. Cette règle est directement **liée à une réponse active** via la commande disableaccount, configurée pour être **exécutée automatiquement** sans délai de réactivation (timeout=0).

La directive `<disabled>no</disabled>` confirme que cette réponse est activée et opérationnelle dans l'environnement Wazuh.

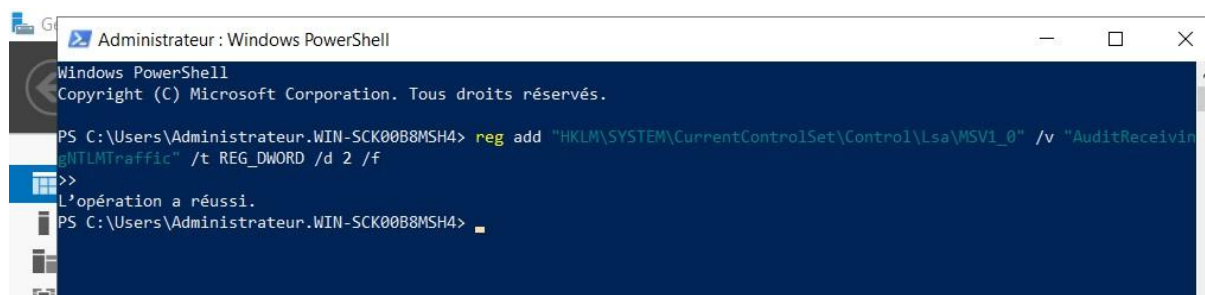
```
sec522@sec522:~$ sudo passwd --status pirate
pirate L 06/01/2025 0 99999 7 -1
sec522@sec522:~$
```

Figure 39: Vérification manuelle : le compte est bien bloqué

La commande `sudo passwd --status pirate` retourne la lettre "L" en début de ligne, ce qui signifie que le compte **pirate est verrouillé**. Cette vérification manuelle confirme que l'action de Wazuh a bien pris effet.

7.4. Attaque sur Active Directory via Responder

Dans le cadre de la sécurisation de l'Active Directory, nous avons mis en place une détection automatisée d'attaques de type **Responder** ciblant l'authentification NTLM. À l'aide de l'agent Wazuh, combiné à une configuration locale d'audit Windows et à des règles personnalisées, nous avons pu non seulement détecter l'attaque, mais également y répondre de manière automatisée. Les captures suivantes retracent l'ensemble du processus, de la détection à la réponse active.



```
Administrateur : Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. Tous droits réservés.

PS C:\Users\Administrateur.WIN-SCK00B8MSH4> reg add "HKLM\SYSTEM\CurrentControlSet\Control\Lsa\MSV1_0" /v "AuditReceivein
gNTLMTraffic" /t REG_DWORD /d 2 /f

>>
L'opération a réussi.
PS C:\Users\Administrateur.WIN-SCK00B8MSH4>
```

Figure 40: Activation de l'audit NTLM via PowerShell

Cette commande PowerShell ajoute une clé de registre permettant d'auditer les tentatives d'authentification NTLM sur la machine cible. Cela est nécessaire pour remonter les événements de type NTLM dans les journaux Windows.

```
<active-response>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>100200</rules_id>
  <timeout>3600</timeout>
</active-response>
```

```
<rule id="100200" level="10">
  <if_sid>61612</if_sid>
  <match>NTLM</match>
  <description>NTLM authentication attempt detected - possible credential theft
  (Responder attack)</description>
  <group>windows,authentication,ntlm,attack,credential_access</group>
</rule>
```

Figure 42: Réponse active : blocage automatique via pare-feu

Figure 41: Réponse active : blocage automatique feu

via pare-

Cette configuration XML de Wazuh définit une réponse active déclenchée par la règle ID 100200. Elle exécute la commande firewall-drop pendant 3600 secondes afin de bloquer l'adresse IP source d'une tentative d'attaque.

La règle personnalisée détecte les événements NTLM associés à l'attaque Responder. Lorsqu'un événement contenant le mot-clé "NTLM" est détecté, et correspond à l'ID 66162, une alerte de niveau 10 est générée.

```
<rule id="100300" level="12">
  <match>hashcat</match>
  <description>Suspicious usage of hashcat (password cracking)</description>
  <group>linux,tool_usage,credential_attack</group>
</rule>
```

Figure 43: Détection d'un outil de post-exploitation : Hashcat

Une autre règle personnalisée permet de détecter l'utilisation de l'outil hashcat, utilisé pour le cracking de mots de passe. Cela renforce la détection des phases de post-exploitation après une compromission.

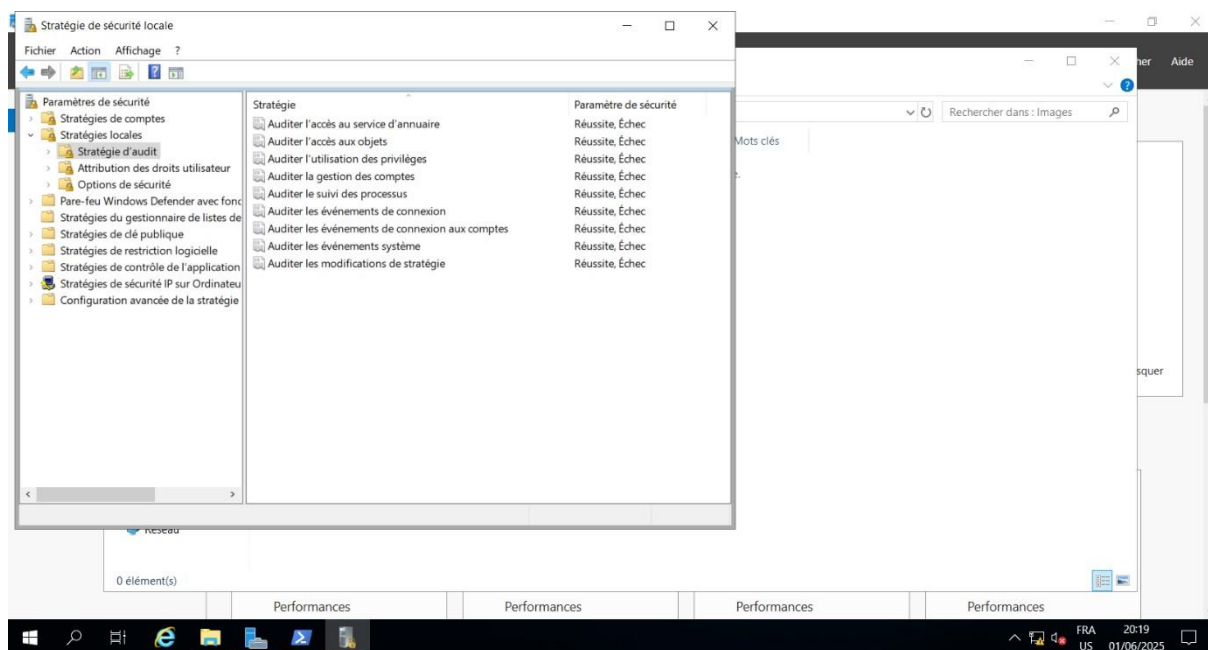


Figure 44: Activation de l'audit avancé dans la stratégie de sécurité locale

Dans la stratégie locale de sécurité Windows, les options d'audit ont été configurées pour capturer les connexions, les accès aux comptes, les privilèges, etc., avec des événements de réussite et d'échec. Ces journaux sont essentiels pour Wazuh.

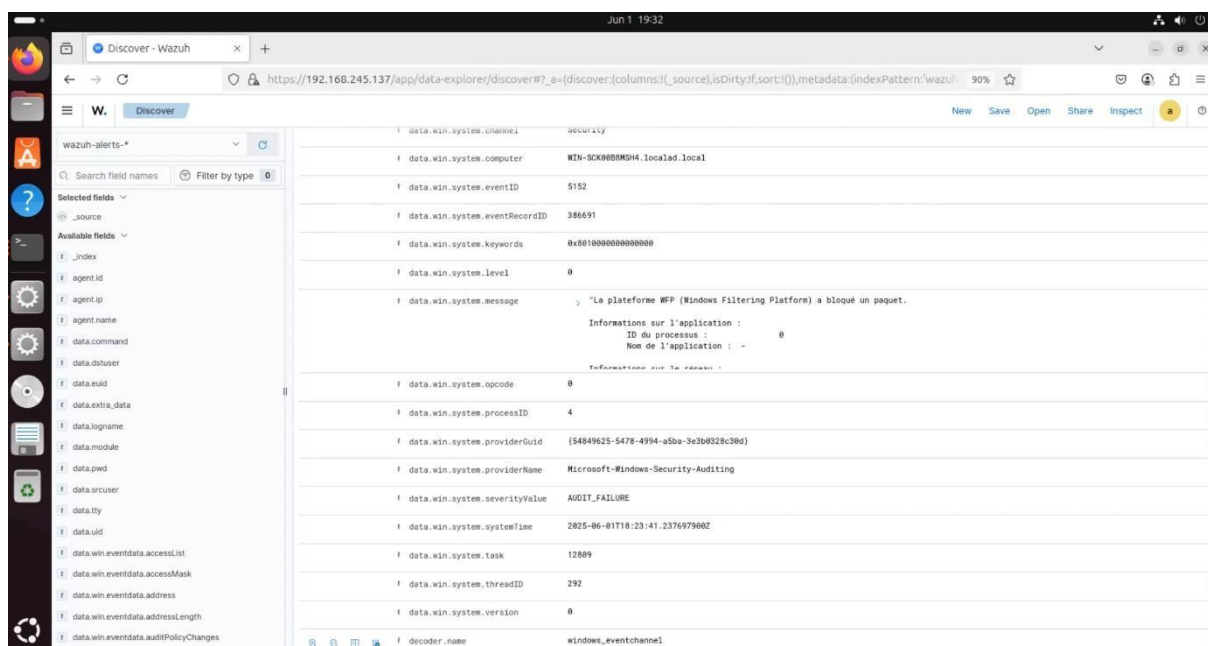


Figure 45:Alerte Wazuh : paquet réseau bloqué par WFP

L'alerte indique que la plateforme WFP (Windows Filtering Platform) a bloqué un paquet réseau entrant suspect. Cette action est la conséquence de la réponse active configurée précédemment.

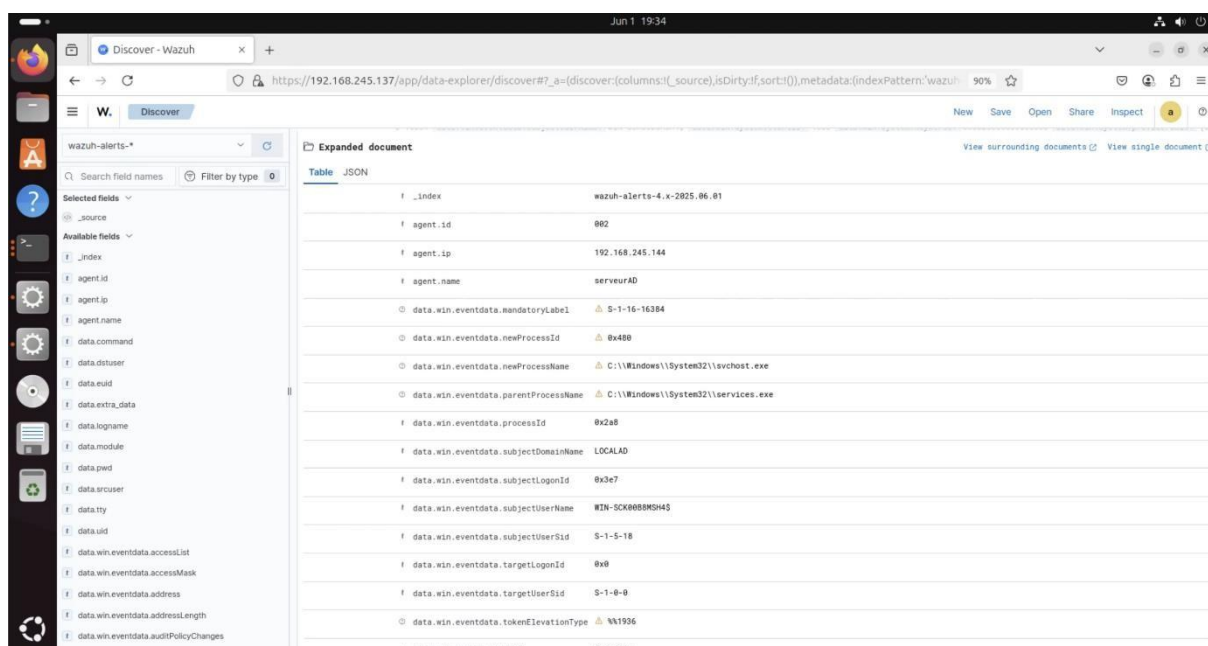


Figure 46: Détail d'un processus suspect sur le contrôleur AD

Cette vue affiche les détails d'un processus lancé (ici svchost.exe) depuis un processus parent (services.exe) sur le serveur Active Directory. Ces informations permettent d'identifier les activités anormales.

New

Save

Open

SI

f data.win.system.channel	Security
f data.win.system.computer	WIN-SCK088MSH4.localad.local
f data.win.system.eventID	5152
f data.win.system.eventRecordID	386691
f data.win.system.keywords	0x8010000000000000
f data.win.system.level	0
f data.win.system.message	La plateforme WFP (Windows Filtering Platform) a bloqué un paquet. Informations sur l'application : ID du processus : 0 Nom de l'application : - Informations sur le réseau : Direction : Entrant Adresse source : 192.168.245.139 Port source : 68 Adresse de destination : 255.255.255.255 Port de destination : 67 Protocole : 17 Informations sur le filtre: ID d'exécution du filtre : 69026 Nom de la couche : Transport ID d'exécution de la couche : 13*
f data.win.system.opcode	0
f data.win.system.processID	4
f data.win.system.providerGuid	{54849625-5478-4994-a5ba-3e3b0328c30d}
f data.win.system.providerName	Microsoft-Windows-Security-Auditing

Figure 47: Détail complet de l'événement de blocage réseau

L'événement Wazuh fournit une vue approfondie du paquet réseau bloqué : IP source, ports, protocole, couche d'exécution, et autres métadonnées système. Cela confirme le bon fonctionnement du mécanisme de blocage.

Conclusion

Ce projet d'intégration d'un SIEM basé sur Wazuh a permis de démontrer l'importance d'une surveillance centralisée et proactive dans la détection et la réponse aux incidents de sécurité. À travers des simulations réalistes d'attaques — brute force, infection par fichier malveillant, attaque sur Active Directory via Responder, ou encore scan réseau — nous avons mis en lumière les capacités du système à identifier des comportements anormaux, générer des alertes pertinentes, et déclencher des réponses automatiques efficaces.

L'intégration d'outils comme Metasploit, Nmap ou Hashcat a renforcé la pertinence des tests réalisés dans un environnement sécurisé. Par ailleurs, les mécanismes d'automatisation configurés (firewall-drop, disable-account) ont montré que Wazuh peut non seulement alerter, mais également réagir de façon autonome pour contenir les menaces.

En conclusion, cette expérience nous a permis de mieux appréhender les enjeux de la cybersécurité opérationnelle, d'approfondir notre maîtrise d'un outil SIEM open-source complet, et de proposer des pistes d'amélioration concrètes pour une gestion dynamique des incidents de sécurité.

Table de Figure

Figure 1: Topologie Du SIEM Utiliser	4
Figure 2: La page de chargementde Wazuh	5
Figure 3: Login Page Wazuh	5
Figure 4: Menu Principale Wazuh	5
Figure 5: La page Principale des agents	6
Figure 6: La page d'ajout d'agent	6
Figure 7: Les 3 agents Ajouter Dans le SIEM	7
Figure 8: L'execution de l'attaque NMAP	8
Figure 9: Reaction du SIEM apres L'attaque NMAP	8
Figure 10: Utilisation de Metasploit avec l'outil ssh_login	8
Figure 11: Visualisation des alertes dans le tableau de bord Wazuh	9
Figure 12: Le message d'alert dans le SIEM (Brute force SSH)	9
Figure 13: L'attaque avec un fichier Malveillant	10
Figure 14: l'exécution du code dans la machine victime	10
Figure 15: Détection de l'attaque par le SIEM	11
Figure 16: Détection de l'ouverture d'une session root via sudo	11
Figure 17: Création d'un utilisateur pirate via une commande root	11
Figure 18: Détection de la création d'un nouvel utilisateur pirate	11
Figure 19: Journal détaillé de la création de	12
Figure 20: Accès depuis Windows Server.....	12
Figure 21: Lancement de l'outil Responder	13
Figure 22: Interception des hashes NTLMv2.....	13
Figure 23: Utilisation de Hashcat pour casser le hash	14
Figure 24: Hash cracké avec succès.....	14
Figure 25: Accès réussi au partage Windows via SMB	15
Figure 26: Détection du scan dans les logs	16
Figure 27: Alerte générée par Wazuh	16
Figure 28: Réponse active exécutée automatiquement (firewall-drop)	17
Figure 29: Configuration de la règle de réponse dans le fichier XML	17
Figure 30: Nouvelle tentative de scan échouée (preuve de blocage)	18
Figure 31: Échec répété de connexions SSH dans les logs	19
Figure 32: Alerte Wazuh déclenchée par fréquence de tentatives	19
Figure 33: Réponse Active : Blocage automatique via firewall-drop	20
Figure 34: Configuration de la réponse active dans le fichier XML	20
Figure 35: Journal détectant l'ajout du compte pirate	21
Figure 36: Alerte générée par Wazuh (Create Account - MITRE T1136)	21
Figure 37: Réaction automatique : désactivation du compte pirate	22
Figure 38: Configuration XML des règles de désactivation	22
Figure 39: Vérification manuelle : le compte est bien bloqué	23
Figure 40: Activation de l'audit NTLM via PowerShell	23
Figure 41: Réponse active : blocage automatique via pare-feu.....	23
Figure 42: Réponse active : blocage automatique via pare-feu	23
Figure 43: Détection d'un outil de post-exploitation : Hashcat	24
Figure 44: Activation de l'audit avancé dans la stratégie de sécurité locale	24
Figure 45: Alerte Wazuh : paquet réseau bloqué par WFP	25
Figure 46: Détail d'un processus suspect sur le contrôleur AD	25
Figure 47: Détail complet de l'événement de blocage réseau	26